

Data Protection Impact Assessment (DPIA)

Gegevensbeschermingseffectbeoordeling

U moet het eerste deel van dit template invullen voor alle gegevensverwerkingen. Hiermee legt u waarom er wel of niet een DPIA moet worden uitgevoerd.

Dit template is gemaakt door de mensen van ICT Institute.

Het template mag gratis worden gebruikt, onder een creative commons licentie

<https://creativecommons.org/licenses/by/4.0/>

De nieuwste versie staat op:

<https://softwarezaken.nl/2022/01/gratis-27001-avg-templates/>

Je mag het template uitbreiden, aanpassen en bewerken zoveel je wilt.

Je mag het template en documenten gemaakt met het template doorgeven en delen zoveel je wilt.

Als je het template doorgeeft, dan moet je "gemaakt door de mensen van ICT Institute" laten staan.

Als je een document maakt met dit template en je bent geen opdrachtgever van ons, zet dan "gemaakt met template van ICT Institute" ergens in het document.

Als je een opdrachtgever bent van ICT Institute, dan mag je alles doen met dit template wat je wilt.

Lees vooral ook deze artikelen als je aan de slag gaat:

<https://softwarezaken.nl/2018/01/gdpr-avg-in-10-stappen/>

<https://softwarezaken.nl/2018/03/avg-template-voor-dpia/>

Bronnen template

Dit template is ontwikkeld op basis van de volgende bronnen:

- De AVG zelf
- De Handleiding Algemene Verordening Gegevensbescherming, uitgave van de Autoriteit Persoonsgegevens. Auteurs: Bart W. Schermer, Dominique Hagenauw, Nathalie Falot
- Richtsnoeren voor gegevensbeschermingseffectbeoordelingen door groep Gegevensbescherming, Zoals laatstelijk gewijzigd en vastgesteld op 4 oktober 2017
- Privacy Impact Assessment (PIA): Introductie, handreiking en vragenlijst Versie 1.2 - November 2015 uitgegeven door NOREA

Organisatiegegevens

Naam, adres van organisatie:

Opsteller DPIA:

Naam en contactgegevens FG (als deze is aangesteld):

Overige betrokkenen en geraadpleegde experts:

Stappenplan uitvoering:

Geef hier aan op welke dag er met wie is gesproken, of op welke dag er workshops zijn geweest en welke partijen/personen hierbij aanwezig waren.

Dit is ook onderdeel van de FRIA uit de AI-verordening.

Gegevens van de verwerking

Beschrijf hier om welke persoonsgegevens het gaat (naam, email, medisch, ...).

Met welk doel en in welk proces worden deze gegevens gebruikt?

Welke groepen betrokkenen zijn de persoonsgegevens van (websitebezoekers, leerlingen, klanten, ...)

Is deze DPIA voor een bestaande situatie, of voor een nieuw voorgestelde situatie?

Heeft deze verwerking te maken met het detecteren of correcties maken van *biases* in AI systemen? (Als dit het geval is, is het gebruiken van bijzondere persoonsgegevens bij uitzondering toegestaan).

Dit is ook onderdeel van de FRIA uit de AI-verordening.

Moet een DPIA worden uitgevoerd?

Een DPIA is verplicht als de gegevensverwerking voorkomt op de volgende lijst met onderwerpen die door de Autoriteit Persoonsgegevens is gepubliceerd:

1. Heimelijk toezicht
2. Zwarte lijsten
3. Fraudebestrijding
4. Creditscores
5. Financiële situatie
6. Genetische persoonsgegevens
7. Gezondheidsgegevens
8. Samenwerkingsverbanden
9. Cameratoezicht

10. Flexibel cameratoezicht
11. Controle werknemers
12. Locatiegegevens
13. Communicatiegegevens
14. Internet of things
15. Profileren
16. Observatie en beïnvloeding van gedrag
17. Biometrische gegevens

Verder is een DPIA verplicht als een gegevensverwerking waarschijnlijk een hoog privacyrisico oplevert voor de betrokkenen (de mensen van wie de organisatie gegevens verwerkt). Dat is in ieder geval zo als een organisatie:

1. systematisch en uitvoerig persoonlijke aspecten evalueert, waaronder profilering;
2. op grote schaal bijzondere persoonsgegevens verwerkt;
3. op grote schaal en systematisch mensen volgt in een publiek toegankelijk gebied (bijvoorbeeld met cameratoezicht).

Om te bepalen of er mogelijk sprake is van een hoog risico hanteren de toezichthouders de onderstaande vuistregel. Er is sprake van een hoog risico men aan twee of meer van de onderstaande negen criteria voldoet:

1. evaluatie van personen of scoretoekenning;
2. geautomatiseerde besluitvorming met rechtsgevolg of vergelijkbaar wezenlijk gevolg;
3. stelselmatige monitoring;
4. gevoelige gegevens of gegevens van zeer persoonlijke aard;
5. op grote schaal verwerkte gegevens;
6. matching of samenvoeging van datasets;
7. gegevens met betrekking tot kwetsbare betrokkenen;
8. innovatieve toepassing van nieuwe technologische of organisatorische oplossing;
9. blokkering van een recht, dienst of contract.

Aan welke criteria voldoet deze verwerking? Geef voor elk criteria een korte motivatie waarom wel of niet.

In het geval van het ontwikkelen van hoog-risico AI-systeem moet deze DPIA uitgebreid worden naar een FRIA volgens de AI-verordening.

Systematische omschrijving van de gegevensverwerking

Beschrijf hier in meer detail hoe de gegevensverwerking gaat.

Hoe / waar wordt de informatie verzameld?

Waar wordt deze opgeslagen? Wie kan hier bij?

Hoe wordt de informatie gebruikt? Wordt elk veld gebruikt?

Wat zijn de doelen van de verwerking? Kunnen deze doelen ook zonder de gegevens worden behaald?

Wordt binnen het proces om toestemming gevraagd? Zijn er latere uitschrijf/opt-out-mogelijkheden?

Wat is de bewaartermijn van de gegevens? Hoe is de verwijdering van de gegevens geregeld?

Welke hardware en software wordt gebruikt bij de gegevensverwerking?

Welke afdelingen, leveranciers en andere partijen zijn als verwerker bij de verwerking betrokken?

Is er sprake van internationale doorgifte? Welke landen betreft dit?

Waar wordt de data gearhiveerd? Is dit papier of digitaal?

Wat is de verwachte omvang van de gegevensverwerking (aantallen betrokkenen)

Dit is ook onderdeel van de FRIA uit de AI-verordening.

Beoordeling noodzaak en proportionaliteit

Is er sprake van een duidelijk gespecificeerd doel? Wat is dit doel precies, en waarom is dit legitiem?

Kan dit doel ook zonder deze persoonsgegevens worden behaald? Waarom niet, of waarom doet u het niet anders?

Is er sprake van een duidelijke maximale bewaartermijn?

Wordt er voldoende informatie verstrekt aan betrokkene? Is het voor betrokkenen duidelijk welke rechten zij hebben en hoe zij deze kunnen uitoefenen?

Hoe is het recht op inzage gewaarborgd?

Hoe is het recht op rectificatie gewaarborgd?

Hoe is het recht op verwijdering gewaarborgd?

Hoe is het recht op overdraagbaarheid van gegevens gewaarborgd?

Beoordeling van de privacyrisico's

Inschatting risico's

Hoe schat u de kans en impact van de volgende risico's:

Risico	Hoe kan dit risico zich voordoen?	Kans dat dit in een jaar gebeurt	Impact op betrokkenen
Onrechtmatige toegang – interne medewerkers		Hoog want..	Laag want...
Onrechtmatige toegang – door buitenstaanders			
Ongewenste wijziging van gegevens – interne medewerkers			
Ongewenste wijziging van gegevens – door buitenstaanders			
Verdwijnen / zoekraken van gegevens			

Wat is de exacte impact van uitlekken van gegevens op betrokkenen?

- Heeft dit nadelige gevolgen voor de persoon?
- Is er kans op financiële schade?
- Is er kans op identiteitsdiefstal of fraude?

Dit onderdeel kan ook meegenomen worden in de FRIA uit de AI-verordening.

Maatregelen

Kunt u per risico aangeven welke maatregelen u neemt om de gegevens te beschermen:

Zijn er nog aanvullende organisatorische maatregelen die u neemt?

Zijn er nog aanvullende technische maatregelen die u neemt?

Is het duidelijk wie na afloop van het project verantwoordelijk is voor het in stand houden en evalueren van de getroffen maatregelen? Wie is dit:

Dit onderdeel kan ook meegenomen worden in de FRIA uit de AI-verordening (maatregelen tegen privacy risico's kunnen onderdeel zijn van de FRIA).

Advies van de FG

Heeft u een Functionaris voor de Gegevensbescherming (FG) benoemd? Dan is het verplicht om deze persoon om advies te vragen. Leg het advies van de FG hieronder vast:

Naam FG:

Datum van advies:

Antwoorden van FG:

Zijn de gegevensverwerking en doeleinden duidelijk omschreven?

Is er de verwerking van de persoonsgegevens noodzakelijk of proportioneel voor de doeleinden?

Zijn de privacyrisico's voldoende in kaart gebracht? Welke risico's ontbreken nog?

Advies van betrokkenen en vertegenwoordigers

Is er voor deze DPIA gesproken met betrokkenen of vertegenwoordigers? Welke reactie hebben zij gegeven? Hoe is deze reactie verwerkt?

Voorafgaande raadpleging

Komt er uit de DPIA dat de verwerking een hoog risico oplevert als u geen risicobeperkende maatregelen neemt? Geef antwoord en motivatie hieronder:

...

Indien ja, dan moet u een voorafgaande raadpleging aanvragen bij de Autoriteit Persoonsgegevens (AP). Hierbij moet u de DPIA aan de AP verstrekken.